

E122

Human-Centric Risk in Cybersecurity

Armored Drill

8 concepts · 12 items · 4 transfer items

What this is. Every concept in this course's public description, re-asked with more disguise than a practice test uses. Each stem carries facts that do not decide it. Every wrong answer is a named trap.

Source. Scope from the course's public description in the WGU Institutional Catalog (September 2026); items written from the field's standard body of knowledge. No WGU assessment item, course material or proprietary content is used or reproduced. Not affiliated with or endorsed by Western Governors University.

Method © 2026 Erik Daniel Lindquist — Course Mastery Coach, armored drill. Items drafted with AI assistance under his direction.

How to run it

Paper first. Pencil. One pass, no notes, a timer if you want the pressure.

1. **Before you read the options**, fill the strip under the item: the target word (what is actually being asked), and the one fact in the stem that decides it.
2. **Principle before arithmetic**. Name the rule, then compute.
3. **Camouflage**. Most of every stem does not matter. Ask: which single fact decides this?
4. **Inverse pairs are the bait**. If two options are opposites, one of them is the trap built for you.
5. **Mark sure, unsure or guess** honestly. Sure-and-wrong is the most valuable miss on the page — it is a wrong mental model.
6. **Absolutes** (always, never, guarantee) are usually wrong. And recognizing an answer is not the same as owning it.
7. Items with a **heavy black bar** on the left are **transfer items**: the same principle, reversed or solved for a different variable.
8. Stop at the STOP page. Then grade, fill the triage grid, and tally the traps you fell for. The biggest tally is what you drill next.

The strip, filled in, looks like this:

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	_____	

Items

1.

An accounts payable clerk at a mid-size logistics firm with offices in three states gets an email that appears to come from the CFO, who is traveling. It says a vendor payment must go out within the hour or the company will lose a major contract, and asks the clerk not to mention it to anyone. The clerk has worked there for six years. Which psychological levers is the message relying on most?

- A. Authority and urgency.
- B. Reciprocity.
- C. Technical exploitation of an unpatched email server.
- D. Familiarity built over the clerk's six years of service.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

2.

A hospital security team learns that an attacker studied a unit clerk's public social media, then sent her alone an email that named her manager and a real training class she had just finished. The hospital runs 400 beds and recently moved to a new EHR vendor. What is the best label for this attack?

- A. Spear phishing.
- B. Whaling.
- C. Vishing.
- D. General phishing.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

3. [TRANSFER — reversed stem / different variable]

Which scenario is an example of vishing?

- A. An employee calls the help desk to report a suspicious email.
- B. A caller claiming to be from the help desk asks an employee to read back a login code.
- C. A tailored email is sent only to the company's CEO.
- D. A text message urges an employee to confirm a package delivery through a link.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

4.

A payroll specialist at a credit union that just won a regional workplace award accidentally emails an unencrypted spreadsheet of member account data to the wrong outside address. She had no intent to harm anyone. She self-reported within ten minutes. Which insider-threat category fits?

- A. Malicious insider.
- B. Negligent (unintentional) insider.
- C. Not an insider incident, because she reported it quickly.
- D. Compromised insider.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

5. [TRANSFER — reversed stem / different variable]

An outside attacker uses a stolen but valid employee login to open company files. The employee knew nothing about it. From an insider-risk view, how is this best classified?

- A. A negligent insider, because every stolen login proves the employee was careless.
- B. Purely an external attack with no insider angle.
- C. A compromised insider account.
- D. A malicious insider.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

6.

A retailer with 2,000 employees shows one 45-minute security video each January. Click rates on simulated phishing tests fall in February but return to the old level by June. The company also upgraded its firewall in March. Which change would most improve lasting behavior?

- A. Make the January video two hours long.
- B. Fire anyone who clicks on any simulated phishing email.
- C. Short, frequent, role-based training with ongoing simulations and feedback.
- D. Rely on the new firewall, since technical controls make training unneeded.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

7.

After a clerk wired funds based on an emailed request to change a vendor's bank account, a manufacturer that sells to 30 countries adopts a rule: any change to vendor bank details must be confirmed by calling the vendor at a phone number already on file, never one given in the request. What kind of control is this?

- A. An administrative, preventive control.
- B. A physical control.
- C. A technical, detective control.
- D. A corrective control, because it was adopted after a loss.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

8. [TRANSFER — reversed stem / different variable]

A security manager needs a technical control whose job is to detect problems. Which choice fits?

- A. A written acceptable-use policy.
- B. Badge-controlled doors to the server room.
- C. Multifactor authentication on all accounts.
- D. Automated alerts from log monitoring of unusual logins.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

9.

A health app startup backed by two venture funds is building a symptom-tracking feature. The product team wants to collect each user's full phone contact list "in case we need it later." Launch is planned for spring. Under privacy by design, what should happen?

- A. Collect the contacts but explain it in the privacy policy.
- B. Collect only the data the feature needs, with protective settings on by default.
- C. Collect now and delete the contacts if a regulator complains.
- D. Never collect any personal data at all.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

10. [TRANSFER — reversed stem / different variable]

Which practice violates the privacy-by-design principle of privacy as the default setting?

- A.** Deleting records once their retention period ends.
- B.** Encrypting stored user data.
- C.** Running a privacy impact assessment before launch.
- D.** New accounts share activity publicly unless the user finds and turns the option off.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

11.

A dental group with eleven clinics finds that front-desk staff can view and edit the full billing ledger, including issuing refunds that no one else approves. No fraud has been found, and staff turnover is low. Which change best reduces human-centric risk?

- A.** Remove all system access from front-desk staff.
- B.** Leave access as is, since no fraud has been found.
- C.** Limit each role to the access it needs and require a second person to approve refunds.
- D.** Require staff to change passwords every year.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

12.

At an engineering firm that recently moved to a hybrid schedule, an employee reports that she typed her password into a fake login page an hour ago. The firm's current policy docks pay for anyone who falls for phishing, and reports of suspicious emails have dropped 60% since that policy began. What should security leadership do?

- A.** Require her to return to the office full time.
- B.** Treat the 60% drop as proof that phishing attempts have fallen.
- C.** Dock her pay as the policy requires, to deter others.
- D.** Thank her, reset her credentials, and move to a non-punitive reporting policy.

Target word	The one fact that decides	Answer	[] sure [] unsure [] guess
_____	_____	___	

STOP

Answers and dissection follow. Finish every item and every strip first.

Key and dissection

Struck-through text is the camouflage: facts that do not decide the item.

1. Answer A Concept 1

An accounts payable clerk at a mid-size logistics firm ~~with offices in three states~~ gets an email that appears to come from the CFO, who is traveling. It says a vendor payment must go out within the hour or the company will lose a major contract, and asks the clerk not to mention it to anyone. ~~The clerk has worked there for six years.~~ Which psychological levers is the message relying on most?

Target word: which psychological lever **Decides:** A senior title plus a one-hour deadline and secrecy.

A	Correct	The CFO's name supplies authority; the one-hour deadline and secrecy create urgency that discourages checking.
B	Confusion set	Reciprocity means giving something first to create a sense of owing; nothing was offered here.
C	Adjacent category	Nothing in the stem involves a software flaw; the attack works on the person.
D	Camouflage	Answers the tenure detail, which does not decide what the message exploits.

2. Answer A Concept 2

A hospital security team learns that an attacker studied a unit clerk's public social media, then sent her alone an email that named her manager and a real training class she had just finished. ~~The hospital runs 400 beds and recently moved to a new EHR vendor.~~ What is the best label for this attack?

Target word: attack label **Decides:** A researched, tailored email aimed at one non-executive employee.

A	Correct	Tailored email aimed at a specific person is spear phishing.
B	Confusion set	Whaling targets senior executives; a unit clerk is not one.
C	Adjacent category	Vishing uses voice calls; this arrived by email.
D	Dropped element	Ignores the research and personal tailoring that make it targeted.

3. Answer B Concept 2 · transfer

Which scenario is an example of vishing?

Target word: reverse: label given, pick the scenario **Decides:** Vishing = social engineering by voice call.

A	Inverted operation	The employee is reporting a threat, not being manipulated; it is a defensive action.
B	Correct	A voice call used to extract a secret is vishing.
C	Adjacent category	That is whaling by email, not a voice attack.
D	Confusion set	That is smishing, which uses text messages.

4. Answer B Concept 3

A payroll specialist at a credit union ~~that just won a regional workplace award~~ accidentally emails an unencrypted spreadsheet of member account data to the wrong outside address. She had no intent to harm anyone. ~~She self-reported within ten minutes.~~ Which insider-threat category fits?

Target word: insider category **Decides:** An accidental act by the employee herself, with no intent.

A	Confusion set	Malicious requires intent to harm; the stem rules that out.
B	Correct	A careless mistake by a trusted employee without intent is negligent insider risk.
C	Camouflage	Fast reporting is good practice but does not change who caused the exposure.
D	Adjacent category	Compromised means an outsider is using the employee's account; she acted herself.

5. Answer C Concept 3 • transfer

An outside attacker uses a stolen but valid employee login to open company files. The employee knew nothing about it. From an insider-risk view, how is this best classified?

Target word: classify when the actor is external but the account is internal **Decides:** A legitimate internal account is being used by someone else.

A	Absolute language	Credentials can be stolen without carelessness; “every” overstates it.
B	Dropped element	Drops the fact that trusted internal access is being used, which is why insider controls matter.
C	Correct	Valid internal credentials used by an outsider make it a compromised insider case.
D	Confusion set	The employee had no intent and did not act.

6. Answer C Concept 4

A retailer ~~with 2,000 employees~~ shows one 45-minute security video each January. Click rates on simulated phishing tests fall in February but return to the old level by June. ~~The company also upgraded its firewall in March.~~ Which change would most improve lasting behavior?

Target word: what builds lasting behavior **Decides:** Gains fade within months of a single yearly session.

A	Dropped element	Keeps the once-a-year model, which is what lets the gains fade.
B	Absolute language	Harsh penalties discourage reporting and hurt the culture that reduces risk.
C	Correct	Regular reinforcement and measurement keep behavior from drifting back.
D	Camouflage	Answers the firewall detail; firewalls do not stop people from being persuaded.

7. Answer A Concept 5

After a clerk wired funds based on an emailed request to change a vendor’s bank account, a manufacturer ~~that sells to 30 countries~~ adopts a rule: any change to vendor bank details must be confirmed by calling the vendor at a phone number already on file, never one given in the request. What kind of control is this?

Target word: control category and function **Decides:** A written procedure that people follow to stop the loss before it happens.

A	Correct	It is a procedure (administrative) that stops a bad payment before it goes out (preventive).
B	Confusion set	Physical controls are barriers such as locks and badges.
C	Adjacent category	No system setting is involved, and it stops rather than spots the problem.
D	Camouflage	When a control was adopted does not decide its function; it prevents future losses.

8. Answer D Concept 5 • transfer

A security manager needs a technical control whose job is to detect problems. Which choice fits?

Target word: reverse: given category and function, choose the control **Decides:** Technical + detective = a system that spots activity after it starts.

A	Adjacent category	A policy is an administrative control.
B	Confusion set	A physical, preventive control.
C	Dropped element	Right category (technical) but its function is preventive, not detective.
D	Correct	A system (technical) that flags activity (detective).

9. Answer B Concept 6

A health app startup ~~backed by two venture funds~~ is building a symptom-tracking feature. The product team wants to collect each user's full phone contact list "in case we need it later." ~~Launch is planned for spring.~~ Under privacy by design, what should happen?

Target word: privacy-by-design decision **Decides:** The contact list has no stated purpose for symptom tracking.

A	Adjacent category	Notice is a separate principle; it does not justify collecting data without a purpose.
B	Correct	Data minimization and privacy as the default are core privacy-by-design principles.
C	Inverted operation	That is reactive; privacy by design is proactive.
D	Absolute language	Some data is needed for the feature; the rule is to limit, not to ban.

10. Answer D Concept 6 · transfer

Which practice violates the privacy-by-design principle of privacy as the default setting?

Target word: reverse: find the violation **Decides:** The user must act to get privacy.

A	Confusion set	That follows the full-lifecycle protection principle.
B	Inverted operation	Encryption supports privacy rather than violating it.
C	Adjacent category	That satisfies the proactive principle; it is not a default-setting issue.
D	Correct	Privacy should be on automatically; here the user must opt out.

11. Answer C Concept 7

A dental group ~~with eleven clinics~~ finds that front-desk staff can view and edit the full billing ledger, including issuing refunds that no one else approves. No fraud has been found, ~~and staff turnover is low.~~ Which change best reduces human-centric risk?

Target word: best access change **Decides:** One role can both create and complete refunds with more access than it needs.

A	Absolute language	Staff still need some access to do their jobs; the fix is to trim, not remove.
B	Camouflage	Answers the no-fraud detail; controls should prevent problems, not wait for them.
C	Correct	Least privilege plus separation of duties removes the single-person path to misuse or error.
D	Adjacent category	Password rules address account theft, not excess access within a role.

12. Answer D Concept 8

At an engineering firm ~~that recently moved to a hybrid schedule~~, an employee reports that she typed her password into a fake login page an hour ago. The firm's current policy docks pay for anyone who falls for phishing, and reports of suspicious emails have dropped 60% since that policy began. What should security leadership do?

Target word: best leadership response **Decides:** Fast reporting limits damage; the penalty is suppressing reports.

A	Camouflage	Answers the hybrid-schedule detail, which did not cause the incident.
B	Wrong stem number	Fewer reports likely means people are hiding incidents, not that attacks fell.
C	Inverted operation	Punishes the very reporting that protects the firm.
D	Correct	Quick reporting let the team contain the issue; a just culture keeps reports coming.

Triage grid

Write each item number in the box it belongs to.

	Right	Wrong
Sure	Owned.	Concept inversion — top priority. A wrong mental model; it survives rewording.
Unsure / guess	Recognition, not mastery. Re-drill with the transfer.	Not learned yet.

Trap tally

For every miss, find the letter you chose in the key and tally its trap. The biggest number is the pattern to drill.

Trap	What it does	In this drill	Your misses
Dropped element	Leaves out a required term or step.	4	
Wrong stem number	A figure copied from the prompt that is not the answer.	1	
Adjacent category	The right idea in the wrong bucket.	9	
Inverted operation	Direction flipped: add/subtract, cause/effect, higher/lower.	4	
Absolute language	Always, never, guarantee — where judgment applies.	4	
Confusion set	Every option is real; the test is exact role-matching.	8	
Camouflage	Answers a stem fact that was never the question.	6	

Anchor rows — the concept list

One row per concept: the rule to lock in, the trap that catches people, and the tell in the question that signals it.

#	Concept	Rule	Trap	Tell
1	Social engineering levers	Social engineering works by triggering psychological levers such as authority, urgency, fear, reciprocity, and social proof to bypass careful thinking.	Thinking social engineering is mainly a technical exploit.	Pressure cues: a boss's name, a deadline, secrecy, or a reward.
2	Phishing variants	Phishing is broad; spear phishing targets a specific person or group; whaling targets senior executives; vishing uses voice; smishing uses text messages.	Calling any targeted email whaling, or any scam email spear phishing.	Who was targeted and through which channel.
3	Insider threat types	Insiders are malicious (intent to harm), negligent (careless mistakes), or compromised (their valid account is used by an outsider).	Treating every insider incident as malicious.	Whether there was intent and whose hands were on the keyboard.
4	Building a security culture	Lasting behavior change comes from frequent, short, role-based training with reinforcement and measurement, not a single annual event.	Believing one yearly training or a new tool fixes human risk.	Results improve briefly, then drift back.
5	Control categories and functions	Controls are administrative (policy and procedure), technical (systems), or physical, and each works as preventive, detective, or corrective.	Calling any control adopted after an incident corrective, or any control involving a computer technical.	Is it a rule people follow, a system setting, or a physical barrier, and does it stop, spot, or fix?
6	Privacy by design	Build privacy in from the start: proactive not reactive, privacy as the default setting, and collect only the data needed for a stated purpose.	Treating a privacy notice as a substitute for limiting collection.	"Collect it in case we need it later" or settings that are public unless changed.
7	Least privilege and separation of duties	Give each role only the access it needs, and split sensitive steps so one person cannot both start and approve them.	Waiting for fraud to appear before trimming access.	One role can both enter and approve money movement.
8	Just culture and reporting	Non-punitive, fast reporting of mistakes limits damage; punishing people who report drives incidents underground.	Reading fewer reports as fewer incidents.	A penalty policy followed by a drop in reports.

Course scope (public description): Human-Centric Risk in Cybersecurity prepares learners to identify and address the human dimensions of cybersecurity risk, including behavioral vulnerabilities, social engineering, and the psychological factors that underlie cybercrime. Learners develop strategies to build a culture of security through technical and procedural controls and apply privacy by design principles to real-world challenges, advancing organizational resilience and trust.